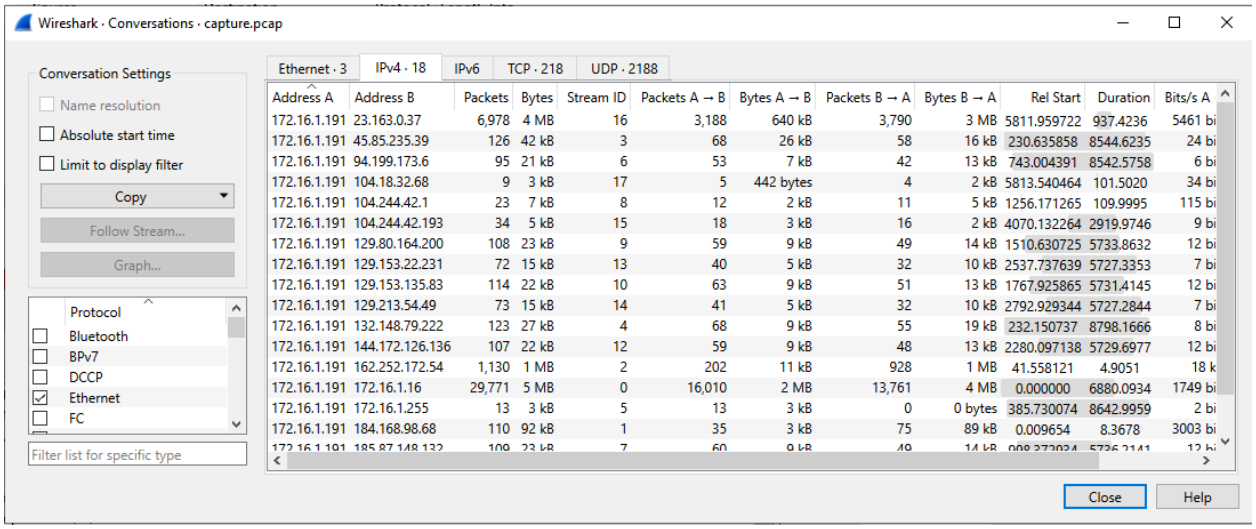
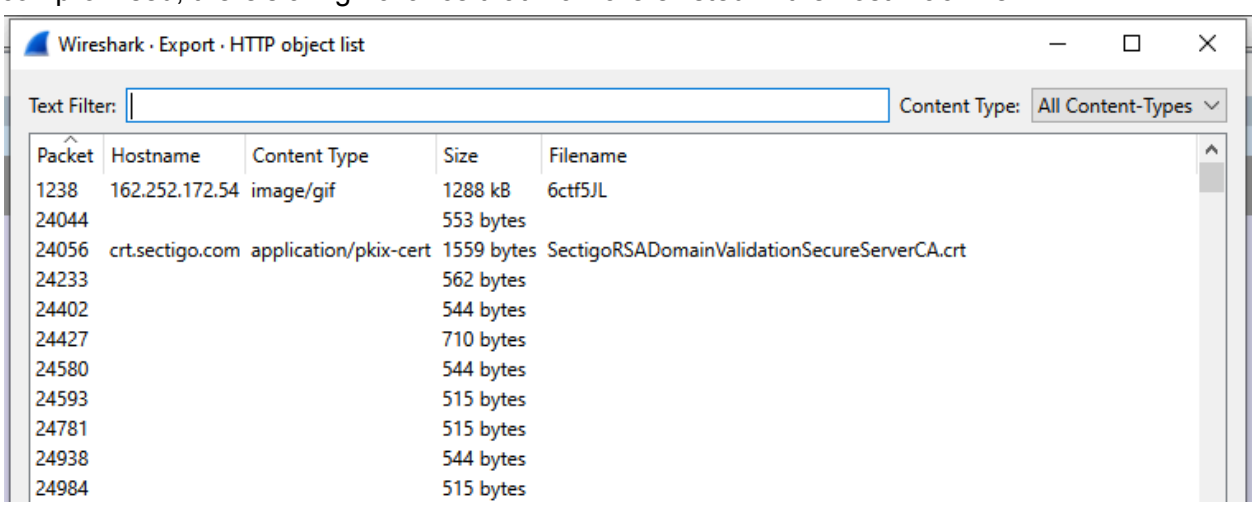
COMPROMISED

Task 1. What is the IP address used for initial access?

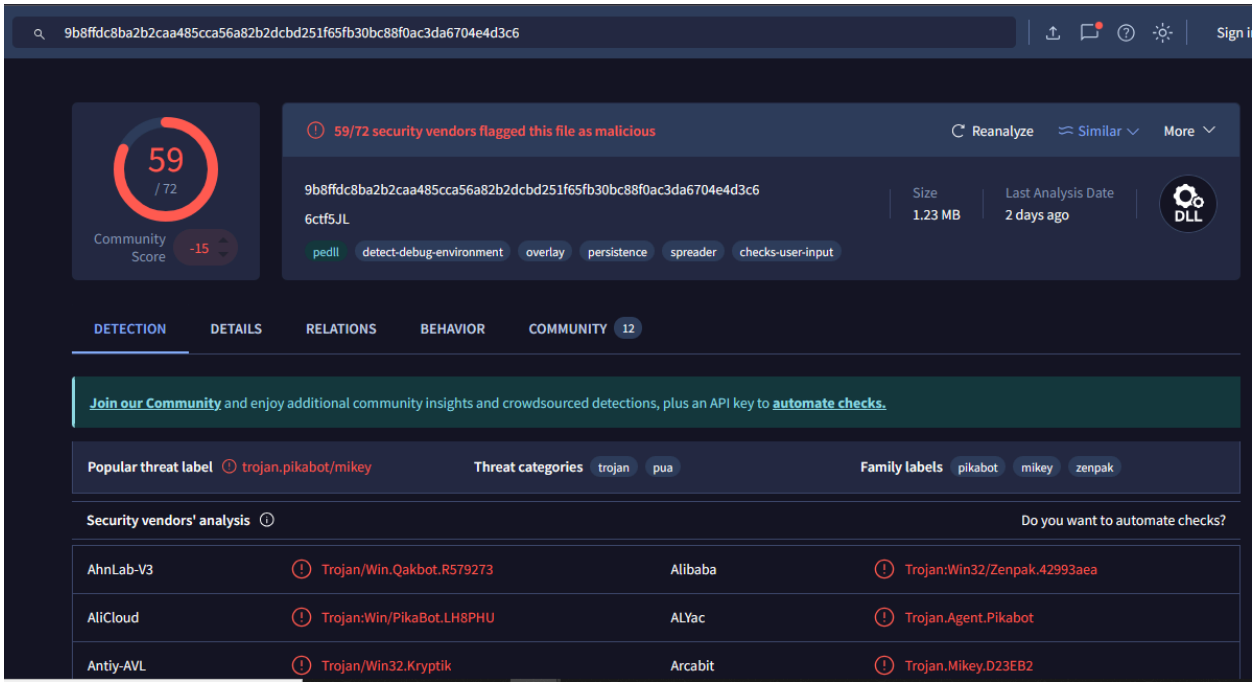


Address A	Address B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A
172.16.1.191	23.163.0.37	6,978	4 MB	16	3,188	640 kB	3,790	3 MB	5811.959722	937.4236	5461 bi
172.16.1.191	45.85.235.39	126	42 kB	3	68	26 kB	58	16 kB	230.635858	8544.6235	24 bi
172.16.1.191	94.199.173.6	95	21 kB	6	53	7 kB	42	13 kB	743.004391	8542.5758	6 bi
172.16.1.191	104.18.32.68	9	3 kB	17	5	442 bytes	4	2 kB	5813.540464	101.5020	34 bi
172.16.1.191	104.244.42.1	23	7 kB	8	12	2 kB	11	5 kB	1256.171265	109.9995	115 bi
172.16.1.191	104.244.42.193	34	5 kB	15	18	3 kB	16	2 kB	4070.132264	2919.9746	9 bi
172.16.1.191	129.80.164.200	108	23 kB	9	59	9 kB	49	14 kB	1510.630725	5733.8632	12 bi
172.16.1.191	129.153.22.231	72	15 kB	13	40	5 kB	32	10 kB	2537.737639	5727.3353	7 bi
172.16.1.191	129.153.135.83	114	22 kB	10	63	9 kB	51	13 kB	1767.925865	5731.4145	12 bi
172.16.1.191	129.213.54.49	73	15 kB	14	41	5 kB	32	10 kB	2792.929344	5727.2844	7 bi
172.16.1.191	132.148.79.222	123	27 kB	4	68	9 kB	55	19 kB	232.150737	8798.1666	8 bi
172.16.1.191	144.172.126.136	107	22 kB	12	59	9 kB	48	13 kB	2280.097138	5729.6977	12 bi
172.16.1.191	162.252.172.54	1,130	1 MB	2	202	11 kB	928	1 MB	41.558121	4.9051	18 k
172.16.1.191	172.16.1.16	29,771	5 MB	0	16,010	2 MB	13,761	4 MB	0.000000	6880.0934	1749 bi
172.16.1.191	172.16.1.255	13	3 kB	5	13	3 kB	0	0 bytes	385.730074	8642.9959	2 bi
172.16.1.191	184.168.98.68	110	92 kB	1	35	3 kB	75	89 kB	0.009654	8.3678	3003 bi

From the IPv4 Conversations tab, the client 172.16.1.191 made a lot of connections to external IPs. Going through each one to find the initial access point would take too long, so instead, I used the Export Objects feature to look for any file downloads. Since the machine is already compromised, there's a high chance that malware existed in the host machine

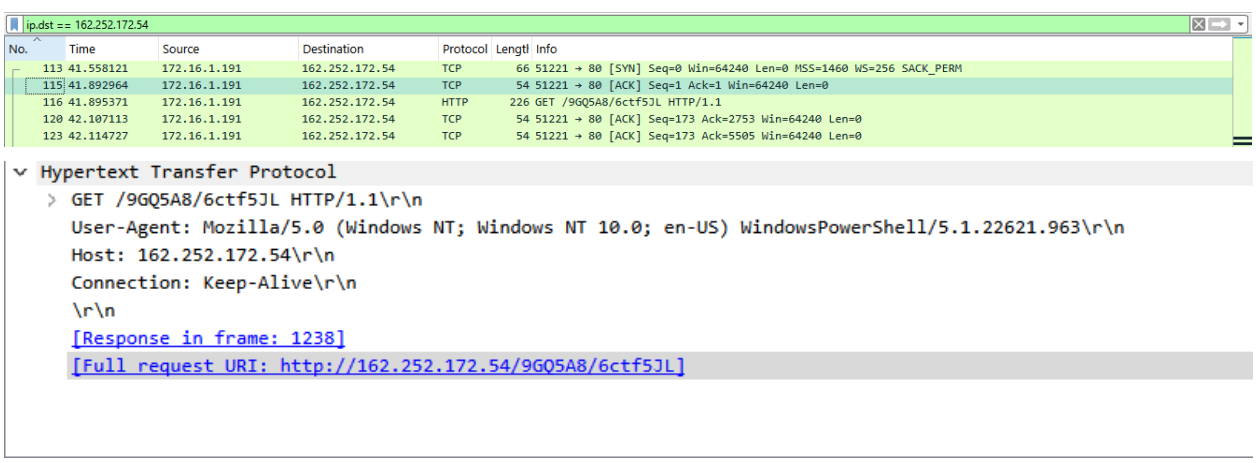


Packet	Hostname	Content Type	Size	Filename
1238	162.252.172.54	image/gif	1288 kB	6ctf5JL
24044			553 bytes	
24056	crt.sectigo.com	application/pkix-cert	1559 bytes	SectigoRSADomainValidationSecureServerCA.crt
24233			562 bytes	
24402			544 bytes	
24427			710 bytes	
24580			544 bytes	
24593			515 bytes	
24781			515 bytes	
24938			544 bytes	
24984			515 bytes	



The user downloaded an image with a suspicious filename: 6ctf5jl. This image/gif file came from the external IP 162.252.172.54, which supports my suspicion that malware was involved. From there, I focused on packets with that destination IP and found one suspicious HTTP connection to http://162.252.172.54/9GQ5A8/6ctf5J and it was made using PowerShell.

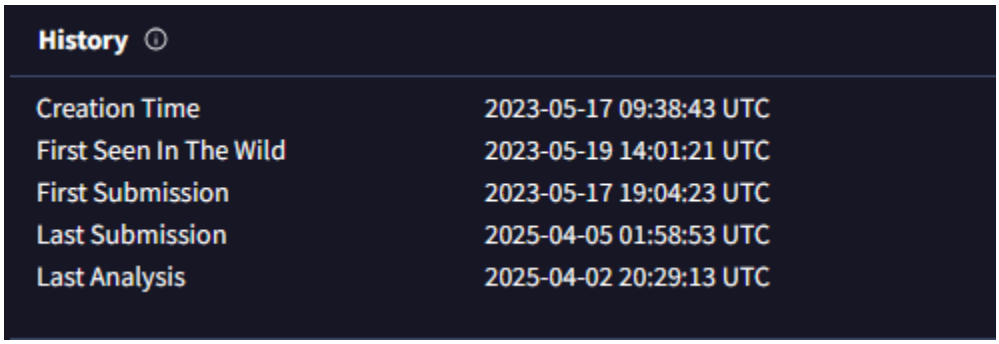
So the ip address used for initial access is **162.252.172.54**



Task 2. What is the SHA256 hash of the malware?
9b8ffdc8ba2b2caa485cca56a82b2dcbd251f65fb30bc88f0ac3da6704e4d3c6

Task 3. What is the Family label of the malware?

Pikabot



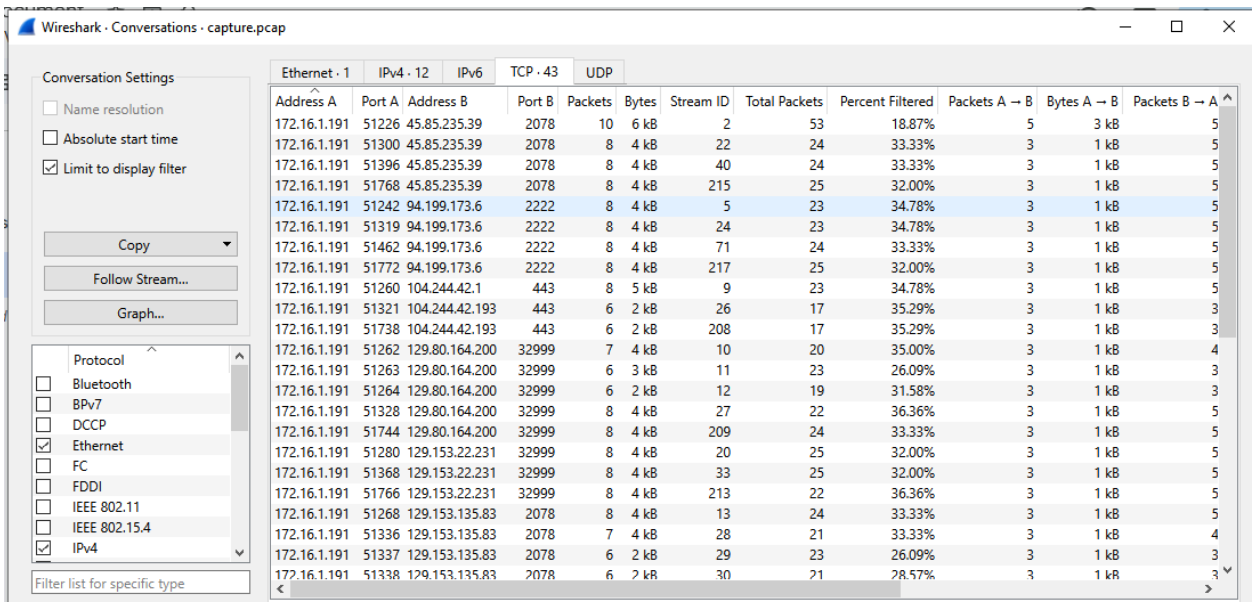
History

Creation Time	2023-05-17 09:38:43 UTC
First Seen In The Wild	2023-05-19 14:01:21 UTC
First Submission	2023-05-17 19:04:23 UTC
Last Submission	2025-04-05 01:58:53 UTC
Last Analysis	2025-04-02 20:29:13 UTC

Task 4. When was the malware first seen in the wild (UTC)?

2023-05-19 14:01:21

Task 5 . The malware used HTTPS traffic with a self-signed certificate. What are the ports, from smallest to largest?



Wireshark · Conversations · capture.pcap

Conversation Settings

- [ ] Name resolution
- [ ] Absolute start time
- [x] Limit to display filter

Copy

Follow Stream...

Graph...

Protocol	
[ ]	Bluetooth
[ ]	BPv7
[ ]	DCCP
[x]	Ethernet
[ ]	FC
[ ]	FDDI
[ ]	IEEE 802.11
[ ]	IEEE 802.15.4
[x]	IPv4

Filter list for specific type

Ethernet · 1 | IPv4 · 12 | IPv6 | TCP · 43 | UDP

Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A
172.16.1.191	51226	45.85.235.39	2078	10	6 kB	2	53	18.87%	5	3 kB	5
172.16.1.191	51300	45.85.235.39	2078	8	4 kB	22	24	33.33%	3	1 kB	5
172.16.1.191	51396	45.85.235.39	2078	8	4 kB	40	24	33.33%	3	1 kB	5
172.16.1.191	51768	45.85.235.39	2078	8	4 kB	215	25	32.00%	3	1 kB	5
172.16.1.191	51242	94.199.173.6	2222	8	4 kB	5	23	34.78%	3	1 kB	5
172.16.1.191	51319	94.199.173.6	2222	8	4 kB	24	23	34.78%	3	1 kB	5
172.16.1.191	51462	94.199.173.6	2222	8	4 kB	71	24	33.33%	3	1 kB	5
172.16.1.191	51772	94.199.173.6	2222	8	4 kB	217	25	32.00%	3	1 kB	5
172.16.1.191	51260	104.244.42.1	443	8	5 kB	9	23	34.78%	3	1 kB	5
172.16.1.191	51321	104.244.42.193	443	6	2 kB	26	17	35.29%	3	1 kB	3
172.16.1.191	51738	104.244.42.193	443	6	2 kB	208	17	35.29%	3	1 kB	3
172.16.1.191	51262	129.80.164.200	32999	7	4 kB	10	20	35.00%	3	1 kB	4
172.16.1.191	51263	129.80.164.200	32999	6	3 kB	11	23	26.09%	3	1 kB	3
172.16.1.191	51264	129.80.164.200	32999	6	2 kB	12	19	31.58%	3	1 kB	3
172.16.1.191	51328	129.80.164.200	32999	8	4 kB	27	22	36.36%	3	1 kB	5
172.16.1.191	51744	129.80.164.200	32999	8	4 kB	209	24	33.33%	3	1 kB	5
172.16.1.191	51280	129.153.22.231	32999	8	4 kB	20	25	32.00%	3	1 kB	5
172.16.1.191	51368	129.153.22.231	32999	8	4 kB	33	25	32.00%	3	1 kB	5
172.16.1.191	51766	129.153.22.231	32999	8	4 kB	213	22	36.36%	3	1 kB	5
172.16.1.191	51268	129.153.135.83	2078	8	4 kB	13	24	33.33%	3	1 kB	5
172.16.1.191	51336	129.153.135.83	2078	7	4 kB	28	21	33.33%	3	1 kB	4
172.16.1.191	51337	129.153.135.83	2078	6	2 kB	29	23	26.09%	3	1 kB	3
172.16.1.191	51338	129.153.135.83	2078	6	2 kB	30	21	28.57%	3	1 kB	3

I started by filtering the packet with TLS since the malware uses https traffic and proceeds with TCP conversations. When malware communicates over the network, it typically does so using TCP connections just like normal software. The TCP tab can provide me with ports used, connections to and from and hunt for possible C2 traffic based on traffic direction. From the result above the client connected to multiple ip address but there are a few ports that were being used repeatedly suggesting that the malware might be using specific ports for its communication possibly a standard C2 infrastructure.There are 4 ports being detected : 2078, 2222, 443, 32999

I ruled out 443 because a self signed malware would not use port 443 to evade detection. It is heavily monitored by firewalls, IDS, IPS and proxies.

-Non-standard ports (2078, 2222, 32999) communicating with external IPs.
-Repeated connections to the same IPs (e.g., multiple streams to 45.85.235.39:2078).
-Different Client src port using the same dst port

So the unusual ports being to for malware communication to the C2 server is **<u>2078, 2222 and 32999</u>**

Task 6. What is the id-at-localityName of the self-signed certificate associated with the first malicious IP?

tcp.stream eq 2

No.	Time	Source	Destination	Protocol	Length	Info
1243	230.635858	172.16.1.191	45.85.235.39	TCP	66	51226 → 2078 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
1244	231.082260	45.85.235.39	172.16.1.191	TCP	58	2078 → 51226 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
1245	231.082404	172.16.1.191	45.85.235.39	TCP	54	51226 → 2078 [ACK] Seq=1 Ack=1 Win=65535 Len=0
1246	231.084815	172.16.1.191	45.85.235.39	TLSv1.2	201	Client Hello
1247	231.085110	45.85.235.39	172.16.1.191	TCP	54	2078 → 51226 [ACK] Seq=1 Ack=148 Win=64240 Len=0
1248	231.375840	45.85.235.39	172.16.1.191	TLSv1.2	1430	Server Hello
1249	231.376008	45.85.235.39	172.16.1.191	TLSv1.2	838	Certificate, Server Key Exchange, Server Hello Done
1250	231.376020	172.16.1.191	45.85.235.39	TCP	54	51226 → 2078 [ACK] Seq=148 Ack=1377 Win=65535 Len=0
1251	231.376097	172.16.1.191	45.85.235.39	TCP	54	51226 → 2078 [ACK] Seq=148 Ack=2161 Win=65535 Len=0
1252	231.399719	172.16.1.191	45.85.235.39	TLSv1.2	147	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
1253	231.399774	45.85.235.39	172.16.1.191	TCP	54	2078 → 51226 [ACK] Seq=2161 Ack=241 Win=64240 Len=0
1254	231.577723	45.85.235.39	172.16.1.191	TLSv1.2	296	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
1255	231.577864	172.16.1.191	45.85.235.39	TCP	54	51226 → 2078 [ACK] Seq=241 Ack=2403 Win=65535 Len=0
1256	231.580440	172.16.1.191	45.85.235.39	TLSv1.2	554	Application Data
1257	231.580476	45.85.235.39	172.16.1.191	TCP	54	2078 → 51226 [ACK] Seq=2403 Ack=741 Win=64240 Len=0
1258	231.580507	172.16.1.191	45.85.235.39	TCP	1514	51226 → 2078 [ACK] Seq=741 Ack=2403 Win=65535 Len=1460 [TCP PDU reassembled in 1273]
1259	231.580512	172.16.1.191	45.85.235.39	TCP	1514	51226 → 2078 [ACK] Seq=2201 Ack=2403 Win=65535 Len=1460 [TCP PDU reassembled in 1273]
1260	231.580516	172.16.1.191	45.85.235.39	TCP	1514	51226 → 2078 [ACK] Seq=3661 Ack=2403 Win=65535 Len=1460 [TCP PDU reassembled in 1273]
1261	231.580521	172.16.1.191	45.85.235.39	TCP	1514	51226 → 2078 [ACK] Seq=5121 Ack=2403 Win=65535 Len=1460 [TCP PDU reassembled in 1273]

The first malicious IP from the TCP tab is 45.85.235.39, so I applied the filter and the above image is the result. The client made a TLS1.2 handshake connection to the server to establish a secure, encrypted communication channel between the client and server

Packet 1249: The server provides its certificate and this is the packet where i can more details about the self signed certificate

```
    signature (sha256WithRSAEncryption)
        Algorithm Id: 1.2.840.113549.1.1.11 (sha256WithRSAEncryption)
    issuer: rdnSequence (0)
      rdnSequence: 6 items (id-at-commonName=votation.bzh,id-at-localityName=Pyopneumopericardium,id-at-organi
    validity
      notBefore: utcTime (0)
          utcTime: 2023-05-14 08:36:52 (UTC)
      notAfter: utcTime (0)
    subject: rdnSequence (0)
      rdnSequence: 6 items (id-at-commonName=votation.bzh,id-at-localityName=Pyopneumopericardium,id-at-organi
    subjectPublicKeyInfo
    extensions: 3 items
  algorithmIdentifier (sha256WithRSAEncryption)
      Algorithm Id: 1.2.840.113549.1.1.11 (sha256WithRSAEncryption)
  Padding: 0
  encrypted […]: b17d152831601028ad4e95c6ebd236689de60b69e2809a6a7a9e36cb115fc82b28b64e1ff55d8f9124d282d8a68f51
```

<u>Pyopneumopericardium</u>

Task 7. What is the notBefore time(UTC) for this self-signed certificate?
2023-05-14 08:36:52

Task 8 . What was the domain used for tunneling?

dns

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	172.16.1.191	172.16.1.16	DNS	76	Standard query 0x0aec A webmasterdev.com
2	0.000293	172.16.1.16	172.16.1.191	DNS	92	Standard query response 0x0aec A webmasterdev.com A 184.168.98.68
1432	1256.155791	172.16.1.191	172.16.1.16	DNS	71	Standard query 0x30f0 A twitter.com
1433	1256.169569	172.16.1.16	172.16.1.191	DNS	135	Standard query response 0x30f0 A twitter.com A 104.244.42.1 A 104.244.42.65 A 104.244.42.193 A 104.244.42.129
1639	2282.671298	172.16.1.191	172.16.1.16	DNS	83	Standard query 0x6394 TXT aaa.h.dns.steasteel.net
1640	2282.696693	172.16.1.191	172.16.1.16	DNS	83	Standard query 0x6394 TXT aaa.h.dns.steasteel.net
1647	2282.818779	172.16.1.16	172.16.1.191	DNS	351	Standard query response 0x6394 TXT aaa.h.dns.steasteel.net TXT
1648	2282.819772	172.16.1.191	172.16.1.16	DNS	83	Standard query 0xb328 TXT baa.h.dns.steasteel.net
1655	2282.852309	172.16.1.191	172.16.1.16	DNS	83	Standard query 0xb328 TXT baa.h.dns.steasteel.net
1656	2282.971855	172.16.1.16	172.16.1.191	DNS	351	Standard query response 0xb328 TXT baa.h.dns.steasteel.net TXT
1657	2282.972753	172.16.1.191	172.16.1.16	DNS	83	Standard query 0x28cf TXT caa.h.dns.steasteel.net
1658	2283.011816	172.16.1.191	172.16.1.16	DNS	83	Standard query 0x28cf TXT caa.h.dns.steasteel.net
1659	2283.142078	172.16.1.16	172.16.1.191	DNS	351	Standard query response 0x28cf TXT caa.h.dns.steasteel.net TXT
1660	2283.143221	172.16.1.191	172.16.1.16	DNS	83	Standard query 0xf622 TXT daa.h.dns.steasteel.net
1661	2283.176865	172.16.1.191	172.16.1.16	DNS	83	Standard query 0xf622 TXT daa.h.dns.steasteel.net
1662	2283.292605	172.16.1.16	172.16.1.191	DNS	351	Standard query response 0xf622 TXT daa.h.dns.steasteel.net TXT
1663	2283.293699	172.16.1.191	172.16.1.16	DNS	83	Standard query 0x8d0e TXT eaa.h.dns.steasteel.net
1664	2283.332384	172.16.1.191	172.16.1.16	DNS	83	Standard query 0x8d0e TXT eaa.h.dns.steasteel.net
1665	2283.462531	172.16.1.16	172.16.1.191	DNS	351	Standard query response 0x8d0e TXT eaa.h.dns.steasteel.net TXT

By filtering the packet with DNS and go to UDP tab there is only one IP address that the client communicate with which is 172.16.1.16 on port53. In DNS tunneling, port 53 appears on the UDP tab in Wireshark conversations because DNS traffic typically uses UDP port 53 for query/response communication

The domain name is **steasteel.net**